

Public-Evidence Banking Cyber Incident and IT GRC Assessment

Bank Syariah Indonesia service disruption - May 2023

Scope boundary
Independent portfolio work using public sources only. No internal access, no leaked data, no forensic conclusion, and no control-effectiveness opinion.

9	7	12	10
public sources	dated events	claims classified	control domains

Executive conclusion

BSI and OJK public records establish a service disruption, a cyber-incident indication, staged recovery, forensic work, supervisory coordination, and later corrective-action statements. The reviewed sources do not establish a final root cause, initial access vector, verified affected-data population, or internal control-test result.

- The 8 May disruption and cyber-incident status are supported by BSI's official disclosure and year-end filing.
- LockBit's data claim remains a reported third-party claim and is excluded from confirmed-fact metrics.
- Control observability: 2 observed actions, 3 partial, and 5 not publicly observable.
- Priority proposals focus on forensic closure, recovery metrics, scenario testing, and personal-data impact assessment.

Evidence model

Class	Treatment
Confirmed or authoritative statement	Use with source attribution and the source's stated boundary.
Reported third-party claim	Document the allegation; do not convert it into a verified incident fact.
Not publicly observable	Leave unresolved; do not call the control failed or invent a technical answer.

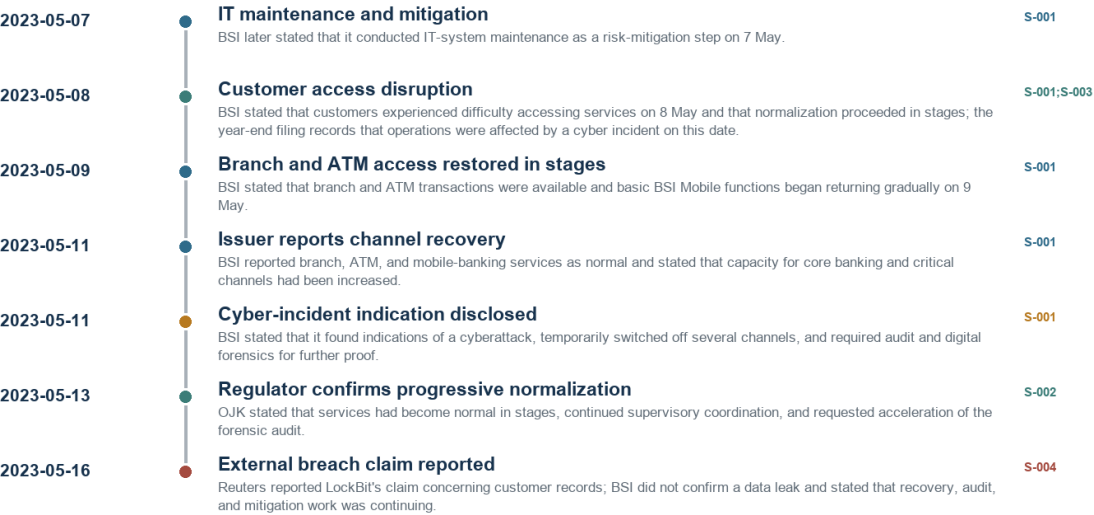
Research cut-off: 13 July 2026 | Core source IDs: S-001 to S-009

1. Public incident chronology

The chart preserves source attribution and does not treat service statements as independent uptime telemetry.

Public incident timeline

Attributed facts and statements - not a forensic reconstruction



Source: data/incident_timeline.csv | Research cut-off: 13 July 2026

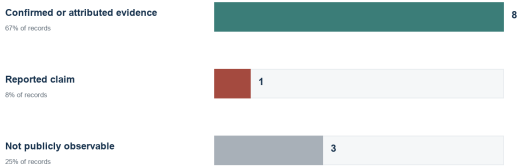
Date	Event	Classification	Sources
2023-05-07	IT maintenance and mitigation	Issuer statement	S-001
2023-05-08	Customer access disruption	Confirmed public fact	S-001;S-003
2023-05-09	Branch and ATM access restored in stages	Issuer statement	S-001
2023-05-11	Issuer reports channel recovery	Issuer statement	S-001
2023-05-11	Cyber-incident indication disclosed	Issuer statement with explicit caveat	S-001
2023-05-13	Regulator confirms progressive normalization	Confirmed public fact	S-002
2023-05-16	External breach claim reported	Reported third-party claim	S-004

Interpretation: the three-calendar-day interval from 8 to 11 May is not measured downtime. BSI's 11 May normal-service wording and OJK's 13 May progressive-normalization wording are retained as separate observations.

2. Evidence classification and control observability

Evidence classification

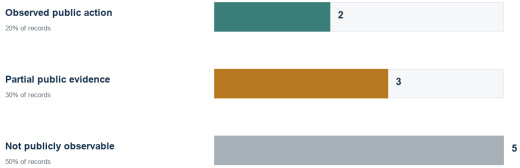
Claims are separated by evidentiary status



Source: data/evidence_claims.csv | External claims are excluded from confirmed test metrics

Control observability

Public evidence is not an internal control test



Source: data/control_observability.csv | Not publicly observable does not mean failed

Material unknowns

Claim	Unknown	Required treatment
C-010	The reviewed public sources do not disclose a final forensic root cause or confirmed initial-access vector.	Do not speculate about phishing vulnerabilities malware path or staff action
C-011	The reviewed primary sources do not publish a verified count or complete inventory of affected personal-data records.	Do not present attacker-supplied numbers as verified
C-012	The reviewed public sources do not contain control test workpapers audit results or evidence sufficient to conclude that specific internal controls were effective or ineffective.	Assess public observability only - not control effectiveness

Control-domain summary

Domain	Public status	Safe conclusion
Disaster recovery	Not publicly observable	No conclusion on control effectiveness
Cyber risk identification	Not publicly observable	No conclusion on control effectiveness
Cyber maturity assessment	Not publicly observable	No conclusion on control effectiveness
Security testing	Not publicly observable	No conclusion on control effectiveness
Detection and containment	Partial public evidence	Action is visible but effectiveness is not assessable
Forensic investigation and coordination	Observed public action	Action is evidenced but audit scope and outcome are not public
Service recovery	Partial public evidence	Recovery activity is visible but recovery capability is not fully assessable
Personal-data protection	Not publicly observable	Do not conclude breach scope or privacy-control effectiveness
Stakeholder communication	Observed public action	Communication occurred; completeness and timeliness are not independently scored
Post-incident improvement	Partial public evidence	Improvement is stated but design and operating effectiveness remain unverified

3. Proposed evidence and remediation priorities

These actions are analyst proposals for a similar regulated-bank environment. They are not attributed to BSI and are not BSI commitments.

Proposed action priority

Analyst recommendations - not BSI commitments

P1 | 0-30 days

50% of records



P1 | 31-90 days

12% of records



P2 | 0-30 days

0% of records



P2 | 31-90 days

38% of records



Source: data/recommendation_register.csv | P1 supports incident closure, recovery assurance, or data-impact decisions

ID	Pri	Horizon	Domain	Recommendation	Expected evidence
R-001	P1	0-30 days	Forensic governance	Create a sanitized post-incident report that separates confirmed facts, disputed claims, root cause, impact, actions, and unresolved items.	Approved sanitized post-incident report and claim register
R-002	P1	0-30 days	Audit evidence	Build a forensic closure pack with evidence chain, affected-system scope, remediation owners, validation tests, and formal risk acceptance for unresolved items.	Evidence index, closure memo, and independent validation record
R-003	P1	0-30 days	Recovery	Document channel-specific RTO and RPO, actual restoration timestamps, dependencies, manual workarounds, and customer-impact metrics.	Recovery scorecard for branch, ATM, mobile, and core dependencies
R-004	P1	31-90 days	Security testing	Run a regulator-aligned ransomware scenario exercise covering detection, isolation, clean-room recovery, data validation, communications, and evidence capture.	Exercise plan, results, lessons learned, and tracked corrective actions
R-005	P1	0-30 days	Data protection	Complete a documented personal-data impact assessment and reconcile any externally reported data claim against verified records and notification duties.	Data-impact assessment, decision log, and notification evidence
R-006	P2	31-90 days	Incident communication	Define a single incident-status taxonomy and evidence-based approval workflow for customer, regulator, investor, and media updates.	Communication matrix, approval workflow, and status definitions
R-007	P2	31-90 days	Third-party resilience	Map critical service dependencies and contractually test escalation, evidence sharing, and recovery support with material technology partners.	Dependency map, contact tree, contract-control checklist, and joint test result
R-008	P2	31-90 days	Management oversight	Create a board-level lessons-learned dashboard covering detection time, containment time, restoration by channel, evidence closure, customer complaints, and overdue actions.	Monthly incident-improvement dashboard with accountable owners

Closure principle: a written policy is not enough. Closure requires implementation evidence, validation results, accountable approval, and explicit acceptance of remaining risk.

4. Source register, method, and limitations

ID	Publisher	Date	Type	Locator	Primary use
S-001	PT Bank Syariah Indonesia Tbk	2023-05-11	Issuer disclosure	Press release, pp. 1-2	Issuer timeline, service restoration statement, cyber-incident indication, and forensic-audit caveat
S-002	Otoritas Jasa Keuangan	2023-05-13	Regulator release	Press release SP-51/OJ K/GKPB/V/2023, p. 1	Regulator status, forensic-audit request, supervisory coordination, and customer-complaint expectations
S-003	PT Bank Syariah Indonesia Tbk	2024-01-30	Audited filing	Note 47(f) - Other Significant Information	Year-end disclosure of the 8 May cyber incident, corrective actions, cybersecurity enhancement, and management's financial-impact view
S-004	Reuters	2023-05-16	Independent reporting	Article body	Independent reporting of the LockBit claim and BSI's response; claim is not treated as verified fact
S-005	Otoritas Jasa Keuangan	2022-07-06	Regulation	Articles 18, 21-26, and 43-45	Binding Indonesian banking IT governance, cyber resilience, recovery, testing, and data-protection requirements
S-006	Otoritas Jasa Keuangan	2022-12-27	Regulatory guidance	Sections II-IX and Appendices I-VI	Cyber-risk assessment, maturity, testing, incident reporting, and evidence expectations for banks
S-007	Government of Indonesia	2022-10-17	Law	Act text	Personal-data protection duties and breach-response context
S-008	National Institute of Standards and Technology	2025-04-03	Technical standard	CSF 2.0 Community Profile	Current incident-response lifecycle and governance reference
S-009	National Institute of Standards and Technology	2016-12-22	Technical standard	Publication overview	Recovery planning, playbooks, testing, metrics, and lessons-learned reference

Assessment method

Collect public sources -> classify authority and claims -> reconstruct timeline -> map regulatory expectations -> assess public observability -> propose evidence-backed actions -> validate data, SQL, wording, links, charts, and PDF.

Limitations

- No internal logs, tickets, policies, contracts, control workpapers, or final forensic report were reviewed.
- Issuer and management statements are attributed and are not treated as independent cyber assurance.
- No alleged leaked data was accessed, inspected, or redistributed.
- Public non-disclosure does not imply control failure; it limits assessment confidence.
- Later disclosures may change the evidence set and should be added as new source records.

Portfolio purpose

Demonstrates source evaluation, incident reconstruction, regulatory mapping, SQL, evidence design, remediation planning, uncertainty management, and executive reporting for an IT Officer or junior IT GRC role.